Analisi del Traffico di Rete con Wireshark

Laboratorio di Cybersecurity — Analisi Pcap e Identificazione di Attacchi

File analizzato	Cattura_U3_W1_L5 (1).pcapng
Pacchetti totali	2083
Host coinvolti	192.168.200.100 (Kali - attaccante) → 192.168.200.150 (Metasploitable 2 - target)
Tipo di attacco	TCP SYN Scan (Half-Open / Stealth Scan)

1. Obiettivo dell'Esercizio

L'obiettivo del laboratorio è analizzare una cattura di traffico di rete in formato .pcapng utilizzando Wireshark, identificare le attività di rete presenti e comprendere la natura dell'interazione tra i due host coinvolti. Il file di cattura è stato trasferito dalla macchina host Windows alla VM Kali Linux tramite una cartella condivisa VirtualBox, quindi aperto e analizzato con Wireshark.

2. Configurazione dell'Ambiente

2.1 Cartella Condivisa VirtualBox

Prima di poter aprire il file di cattura su Kali Linux, è stato necessario configurare una cartella condivisa tra il sistema host Windows e la macchina virtuale. Questa operazione permette di trasferire file tra i due sistemi senza passare dalla rete.

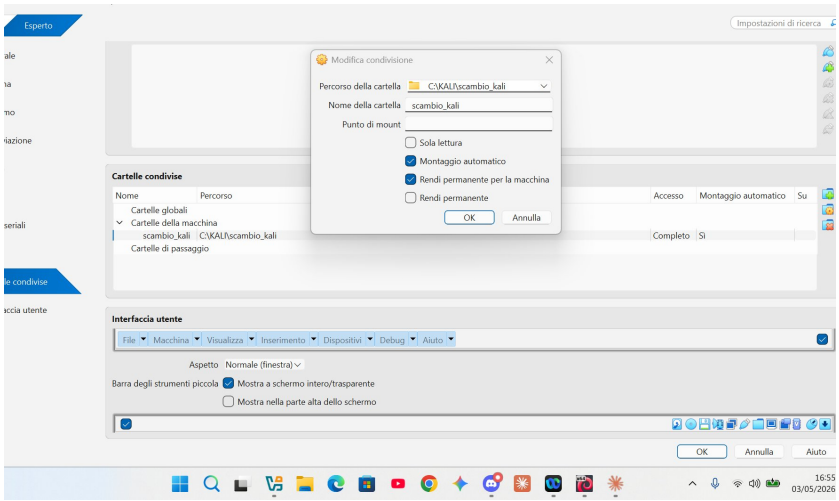

Figura 1 — Configurazione della cartella condivisa in VirtualBox: percorso C:\KALI\scambio_kali, nome scambio_kali, montaggio automatico attivato, accesso completo abilitato

La cartella condivisa è stata configurata con i seguenti parametri:

- Percorso host: C:\KALI\scambio_kali
- Nome cartella: scambio_kali

- Montaggio automatico: attivato — la cartella viene montata ad ogni avvio della VM
- Rendi permanente per la macchina: attivato
- Accesso: Completo (lettura e scrittura)

Il montaggio automatico fa sì che VirtualBox monti la cartella condivisa all'avvio della VM, rendendola accessibile nel percorso /media/sf_scambio_kali all'interno di Kali Linux. Il prefisso sf_ è la convenzione standard di VirtualBox per le cartelle condivise (SharedFolder).

2.2 Navigazione al File su Kali Linux

Una volta avviata la VM, è stato necessario navigare nel filesystem di Kali Linux per raggiungere la cartella condivisa e verificare la presenza del file di cattura.

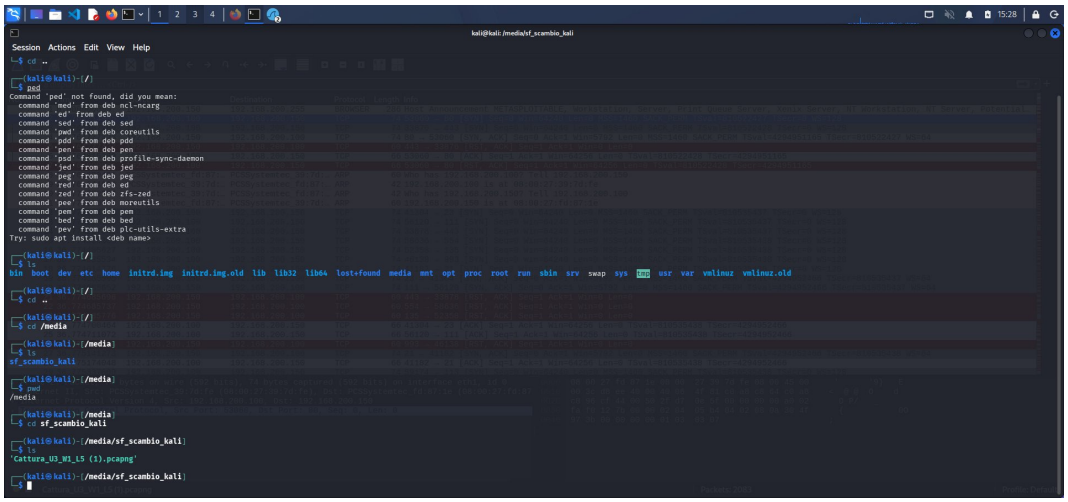

Figura 2 — Navigazione nel filesystem di Kali Linux verso la cartella condivisa /media/sf_scambio_kali. Visibile il file Cattura_U3_W1_L5 (1).pcapng nella directory

La sequenza di comandi eseguita è la seguente:

- cd .. — risalita progressiva alla directory radice /
- ls — verifica del contenuto della root (bin, boot, dev, etc, home, media, mnt...)
- cd /media — spostamento nella directory /media, punto di montaggio delle cartelle condivise
- ls — conferma della presenza di sf_scambio_kali
- cd sf_scambio_kali — accesso alla cartella condivisa
- ls — rilevamento del file Cattura_U3_W1_L5 (1).pcapng

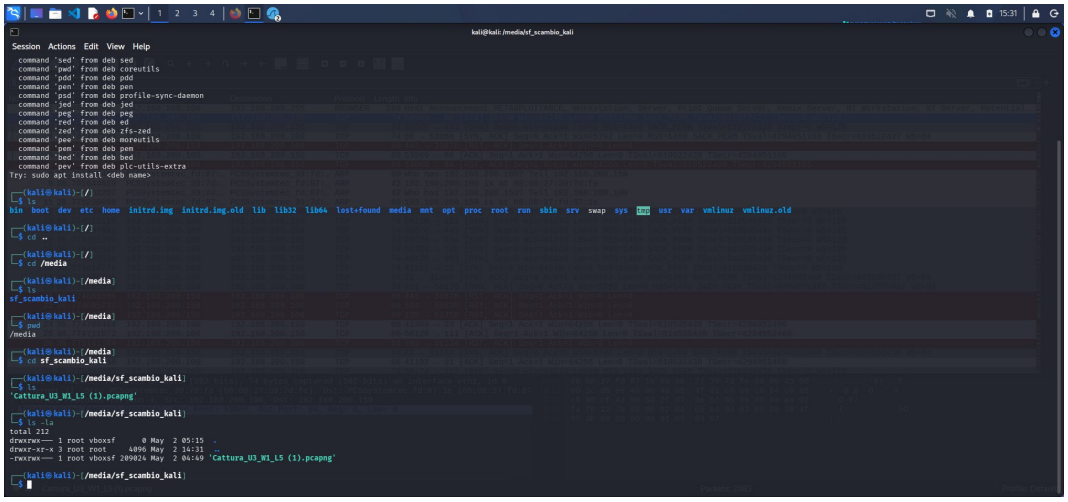

Figura 3 — Output del comando ls -la: il file pcapng ha una dimensione di 209024 byte (circa 209 KB), appartiene all'utente root con gruppo vboxsf (VirtualBox Shared Folders)

Il comando ls -la mostra i dettagli completi: dimensione 209024 byte e proprietà del gruppo vboxsf, creato automaticamente da VirtualBox per gestire i permessi di accesso alle cartelle condivise.

3. Analisi del File con Wireshark

3.1 Vista Generale del Traffico

All'apertura del file pcapng in Wireshark si osserva immediatamente la struttura del traffico catturato. La cattura comprende 2083 pacchetti totali. Il primo pacchetto è di tipo BROWSER (NetBIOS/SMB), mentre il traffico predominante è TCP tra i due host della rete 192.168.200.0/24.

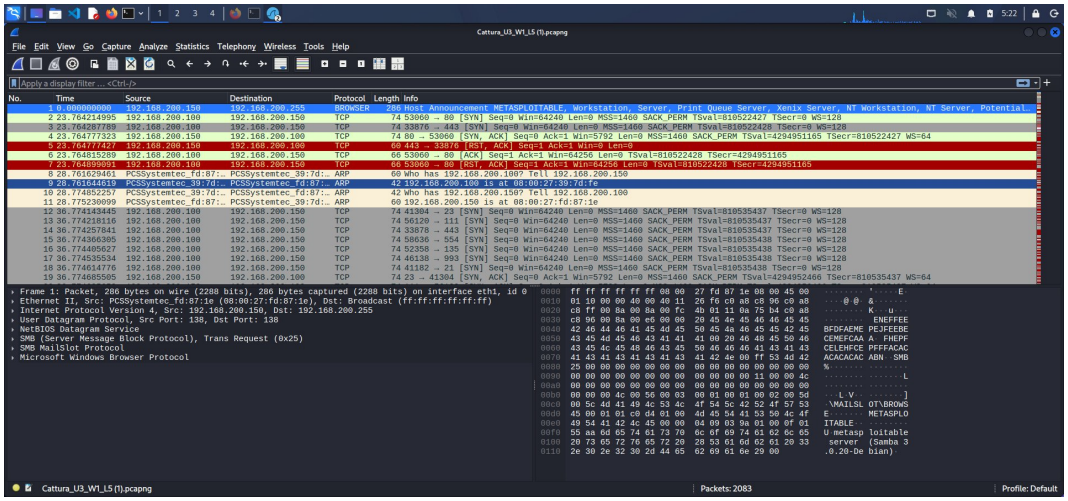

Figura 4 — Vista iniziale del file pcapng in Wireshark senza filtri: i pacchetti in rosso sono RST/ACK (porte chiuse), quelli grigi sono SYN dell'attaccante. Il pattern alternato è la firma tipica di un port scan

La colorazione automatica di Wireshark permette di identificare immediatamente il tipo di traffico:

- Righe rosse: risposte TCP con flag RST/ACK — il target rifiuta la connessione perché la porta è chiusa
- Righe grigie/bianche: pacchetti TCP SYN inviati dall'attaccante verso porte diverse del target
- Il pattern ciclico SYN → RST/ACK è la firma inequivocabile di un port scan automatizzato

Il primo pacchetto (frame 1) è un annuncio NetBIOS/SMB da parte di Metasploitable 2 (192.168.200.150) in broadcast. Nell'hex dump in basso si legge chiaramente "METASPLOITABLE" con i servizi attivi: Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server. Questo rivela che il target esegue Samba (Samba 3.0.20-Debian), confermato dalla stringa visibile nell'hex dump.

3.2 Analisi del Primo Scambio TCP: Three-Way Handshake e Reset

Analizzando i primi pacchetti TCP è possibile ricostruire il tentativo di connessione iniziale. La sequenza mostra il comportamento tipico di un TCP SYN Scan (Half-Open Scan), eseguibile con Nmap tramite l'opzione -sS.

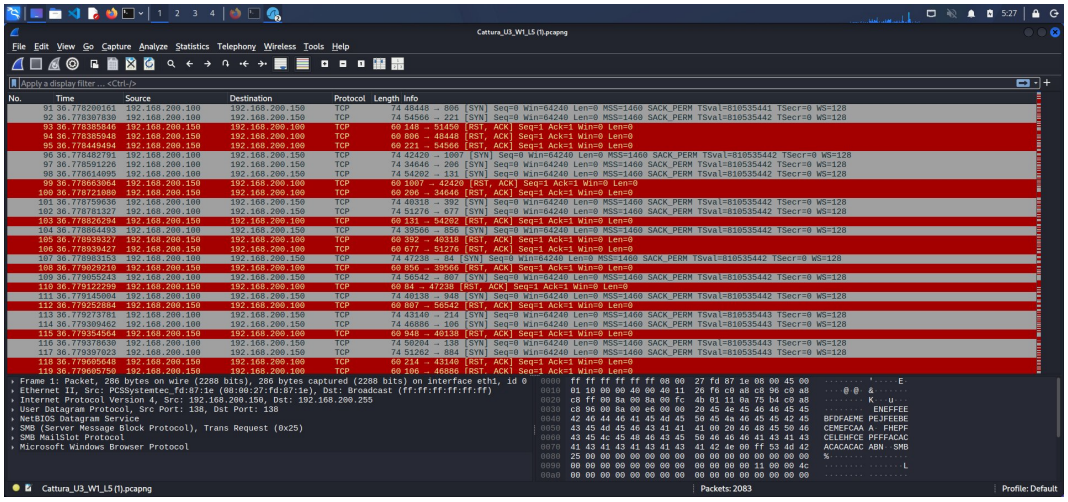

Figura 5 — Dettaglio dei pacchetti a metà cattura: il pattern SYN/RST continua su numerose porte. L'alternanza tra tentativi di connessione (grigi) e risposte di rifiuto (rosso) è chiaramente visibile

I pacchetti 2-7 mostrano il classico pattern del port scan SYN:

- Pacchetto 2: SYN da 192.168.200.100 porta 53060 → 192.168.200.150 porta 80 — avvio tentativo
- Pacchetto 3: SYN/ACK da 192.168.200.150 — la porta 80 è APERTA, il target risponde
- Pacchetto 4: ACK — completamento del three-way handshake
- Pacchetti 5-7: RST/ACK — l'attaccante chiude immediatamente la connessione senza inviare dati

Questo comportamento è caratteristico del SYN scan: lo scanner apre le connessioni solo per verificare se la porta risponde, poi le chiude subito con un RST. Il three-way handshake non viene mai completato correttamente, riducendo la traccia nei log applicativi del sistema target.

3.3 Filtro sui Pacchetti SYN Puri

Applicando il filtro Wireshark **tcp.flags.syn==1 and tcp.flags.ack==0** vengono isolati esclusivamente i pacchetti SYN puri, cioè i tentativi di connessione iniziati dall'attaccante. Questo filtro elimina i SYN/ACK del target e i reset, mostrando solo le sonde dell'attaccante verso ogni porta.

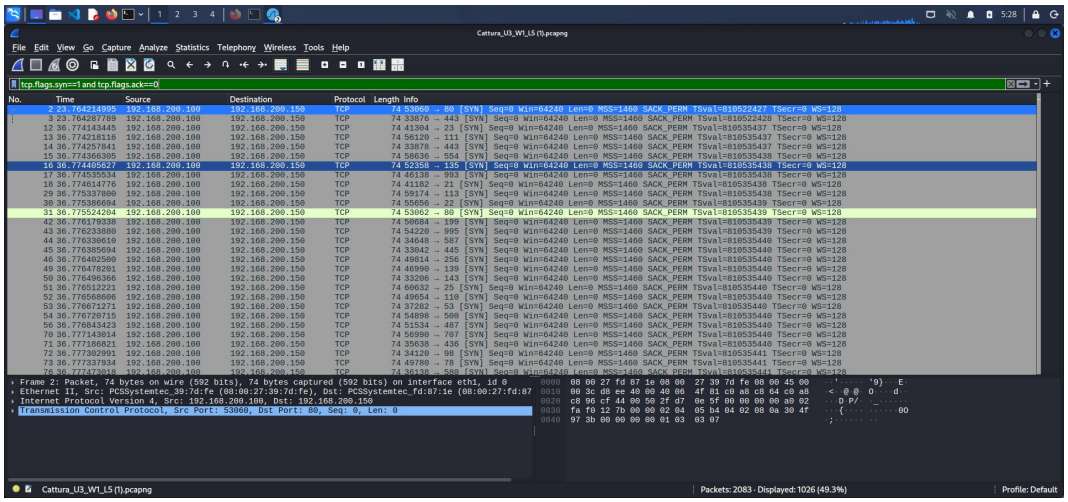

Figura 6 — Filtro tcp.flags.syn==1 and tcp.flags.ack==0: vengono mostrati 1026 pacchetti su 2083 totali (49.3%), tutti da 192.168.200.100 verso 192.168.200.150 su porte diverse

Il risultato è molto significativo: 1026 pacchetti su 2083 (49.3% del totale) sono SYN puri in uscita dall'attaccante. Ogni pacchetto è diretto verso una porta diversa del target. Il numero elevato di SYN in un breve arco di tempo è la firma inequivocabile di un port scan automatizzato. La porta sorgente

cambia ad ogni tentativo per eludere eventuali meccanismi di rate-limiting.

3.4 Identificazione di una Porta Aperta

Nella sequenza intorno ai frame 164-165 si osserva qualcosa di diverso: compare un SYN/ACK con Win=5792, un valore di window size diverso rispetto al Win=64240 standard. Questo momento è cruciale perché rivela una porta effettivamente aperta sul target.

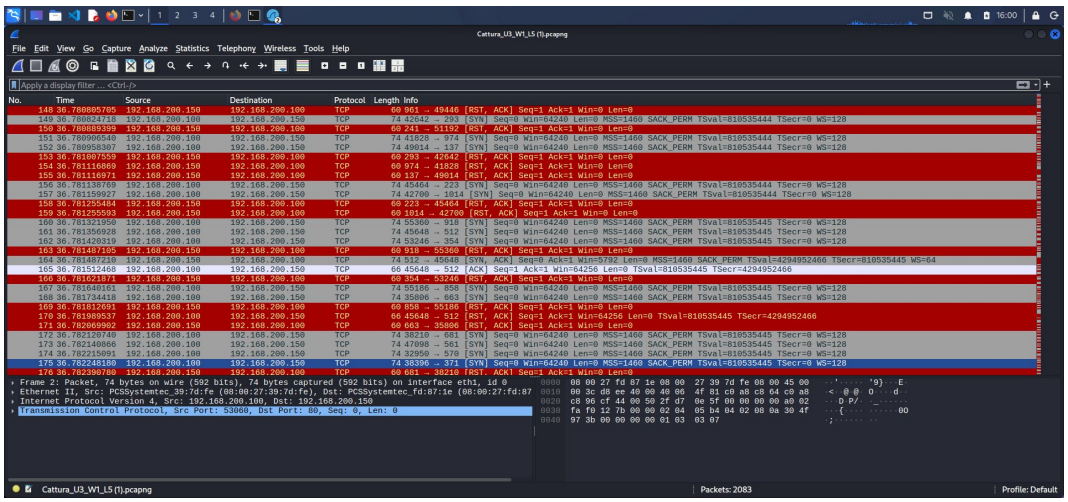

Figura 7 — Ai frame 164-165 si nota un SYN/ACK con Win=5792 e TSval=4294952466 insolito, indicante un processo server in ascolto. L'attaccante risponde con RST per non completare il handshake

Analizzando il frame 164 nel pannello inferiore si notano dettagli importanti:

- TCP SYN/ACK con Seq=0, Ack=1, Win=5792 — window size diversa dagli altri (5792 vs 64256 standard)
- TSval=4294952466 — timestamp insolito, indica un processo server in ascolto attivo
- Frame 165: RST/ACK da parte dell'attaccante — connessione chiusa deliberatamente

Questa è la tecnica dello stealth scan: l'attaccante identifica la porta come aperta grazie al SYN/ACK ricevuto, poi invia un RST invece di completare l'handshake. La connessione non viene mai stabilita completamente, e nelle versioni meno recenti dei sistemi operativi non veniva nemmeno registrata nei log applicativi, rendendo questo tipo di scan difficile da tracciare.

4. Riepilogo e Conclusioni

L'analisi del file pcapng ha permesso di ricostruire in modo completo lo scenario di attacco e identificare con certezza la tecnica utilizzata.

Tecnica rilevata	TCP SYN Scan (Stealth Scan) — tipicamente eseguito con Nmap -sS
Attaccante	192.168.200.100 (Kali Linux)
Target	192.168.200.150 (Metasploitable 2 — identificato dal frame NetBIOS)
SYN inviati	1026 su 2083 totali (49.3% del traffico catturato)
Indicatori chiave	Pattern SYN/RST alternato, assenza di dati applicativi, porte di destinazione variabili

Il port scan SYN è una delle tecniche di ricognizione più comuni nelle fasi iniziali di un attacco informatico (fase di *enumeration* nella metodologia di penetration testing). Il suo scopo è mappare le

porte aperte sul target per identificare i servizi in esecuzione e le potenziali vulnerabilità da sfruttare nelle fasi successive (*exploitation*). La natura "stealth" di questo scan lo rende difficile da rilevare con sistemi IDS/IPS poco configurati, sebbene la densità anomala di pacchetti SYN in un breve intervallo sia un segnale di allarme identificabile con regole appropriate come quelle di Snort o Suricata.